# Wo steht unsere Anmeldung?

Betrieb: Muster Elektrotechnik e.U. Datum: 23. Oktober 2026

Quellen geprüft: 19. Oktober 2026; berichtigte Stellen 23. Oktober 2026

**Mindestens einer der drei ersten Schritte ist offen.**

Schritt 1 offen, Schritt 2 offen, Schritt 3 offen. Die drei Schritte sind das, was die unten genannten Stellen zuerst empfehlen, und das, wonach Sicherheitsfragebögen von Kunden und Versicherern fragen.

## Was Sie angegeben haben

| | |
|---|---|
| MFA bei E-Mail | Nein |
| MFA bei Administration und Fernzugriff | Nein |
| Zweiter Faktor | Keiner, oder wir wissen es nicht |
| Passwort-Manager | Nein |
| Geteilte Konten | Nein |
| Passwortregeln | Keine Regeln |
| Austritte | Nein |
| Wiederherstellung | Nein |

## Wo Sie stehen

Schritt 1: ein zweiter Faktor auf jedem Konto, das zählt — OFFEN
E-Mail- oder Administratorkonten ohne zweiten Faktor, oder niemand weiß es.

Schritt 2: ein langes Passwort je Konto, verwaltet von einem Passwort-Manager — OFFEN
Geteilte Logins, oder weder Passwort-Manager noch Längenregel.

Schritt 3: ein Konto je Person, Austritte am selben Tag, Wiederherstellung geprobt — OFFEN
Konten ausgetretener Personen werden nicht am selben Tag deaktiviert, oder niemand weiß es.

## Befunde

**FAKT** Die US-Normungsstelle NIST hat im Juli 2025 die Revision 4 ihrer Digital Identity Guidelines veröffentlicht; sie ersetzt die Revision 3. Für Passwörter verlangt sie: mindestens 15 Zeichen, wenn das Passwort der einzige Faktor ist, und mindestens 8 Zeichen, wenn es Teil einer Multi-Faktor-Authentifizierung ist; keine weiteren Kompositionsregeln wie vorgeschriebene Mischungen von Zeichenarten; keinen regelmäßigen Wechsel, aber einen erzwungenen Wechsel bei Hinweisen auf eine Kompromittierung; eine Prüfung jedes neuen Passworts gegen eine Sperrliste häufig benutzter, erwartbarer oder kompromittierter Passwörter; und dass Passwort-Manager und automatisches Ausfüllen erlaubt sind; Einfügen zu erlauben, empfiehlt sie. Fehlversuche werden begrenzt.

→ NIST SP 800-63B-4, Digital Identity Guidelines: Authentication and Authenticator Management, Juli 2025, Abschnitte 3.1.1.1, 3.1.1.2 und 3.2.2 · pages.nist.gov/800-63-4/sp800-63b.html · Abruf 2026-10-19, Abschnitt 3.1.1.2 · Abruf 2026-10-23

**FAKT** Das Bundesamt für Sicherheit in der Informationstechnik (BSI) schreibt, dass der Rat zum regelmäßigen Passwortwechsel überholt ist: Regelmäßige, anlassunabhängige Wechsel führen erfahrungsgemäß zu schwächeren Passwörtern, und Arbeitgeber sollten sie weder fordern noch technisch erzwingen. Ein Passwort wird geändert, wenn der Verdacht besteht, dass es abgeflossen ist. Stattdessen empfiehlt das BSI starke Passwörter, einen zweiten Faktor oder Passkeys und einen Passwort-Manager. Sein IT-Grundschutz-Baustein ORP.4 verlangt, dass jede Benutzerkennung eindeutig einer Person zugeordnet werden kann, dass bei personellen Veränderungen nicht mehr benötigte Kennungen und Berechtigungen entfernt werden, dass ein Passwort nie mehrfach verwendet wird, dass Systeme nur mit validem Grund zum Wechsel auffordern und rein zeitgesteuerte Wechsel vermeiden, und dass eine schriftliche Hinterlegung nur für den Notfall existiert und sicher aufbewahrt wird.

→ BSI, Pressemitteilungen vom 31. Januar 2025 („Passwortwechseln war gestern“) und 30. Januar 2026 („Der Ändere-dein-Passwort-Tag braucht ein Update“) · bsi.bund.de · Abruf 2026-10-19; BSI, IT-Grundschutz-Kompendium, Baustein ORP.4 Identitäts- und Berechtigungsmanagement, Anforderungen A1, A2, A8, A22, A23, und Baustein ORP.2 Personal, A2, Edition 2023 · bsi.bund.de · Abruf 2026-10-19

**FAKT** Die US-Cybersicherheitsbehörde CISA ordnet die Formen der Multi-Faktor-Authentifizierung von stark nach schwach: phishing-resistente Verfahren (FIDO/WebAuthn-Sicherheitsschlüssel und Passkeys, PKI); App-basierte Einmalcodes, Push-Benachrichtigungen mit Zahlenabgleich und Hardware-Token; Push-Benachrichtigungen ohne Zahlenabgleich; und Codes per SMS oder Anruf, die für Phishing, SS7- und SIM-Swap-Angriffe anfällig sind und nur als letzte Möglichkeit verwendet werden sollten. Für kleine und mittlere Betriebe, die phishing-resistente MFA nicht sofort umsetzen können, nennt CISA App- oder Token-Codes und Push mit Zahlenabgleich als beste Optionen. Im Juni 2022 sagte die Direktorin der CISA, Multi-Faktor-Authentifizierung mache es um 99 % unwahrscheinlicher, gehackt zu werden; eine Microsoft-Studie mit echten Angriffsdaten fand, dass sie das Risiko einer Kompromittierung um 99,2 % senkt.

→ CISA, Fact Sheet „Implementing Phishing-Resistant MFA“, Oktober 2022, S. 1 bis 3 · cisa.gov · Abruf 2026-10-19; CISA, Pressemitteilung vom 6. Juni 2022 und Blog vom 5. Mai 2022 · cisa.gov · Abruf 2026-10-19; Microsoft Digital Defense Report 2023 und Microsoft Research, „How effective is multifactor authentication at deterring cyberattacks?“, Mai 2023 · microsoft.com · Abruf 2026-10-19

**FAKT** Der Leitfaden der ENISA für kleine und mittlere Betriebe empfiehlt eine Passphrase aus mindestens drei zufälligen Wörtern; für gewöhnliche Passwörter rät er weiter zu gemischten Zeichenarten, die NIST nicht mehr verlangt. Er verlangt, Passwörter nie wiederzuverwenden oder zu teilen, die Multi-Faktor-Authentifizierung zu aktivieren, einen eigenen Passwort-Manager zu nutzen, für den Fernzugriff starke Passwörter und möglichst MFA zu erzwingen, und dass der Zugang von Beschäftigten zu den Systemen beim Austritt entzogen wird.

→ ENISA, „Cybersecurity guide for SMEs: 12 steps to securing your business“, Juni 2021, Schritte 4 und 5 und der Schritt zum Fernzugriff (Schritt 4 · Abruf 2026-10-23); ENISA, „Cybersecurity for SMEs: Challenges and Recommendations“, Juni 2021, S. 36 bis 37 · enisa.europa.eu · Abruf 2026-10-19

**FAKT** Das österreichische Portal onlinesicherheit.gv.at empfiehlt mindestens zwölf Zeichen für normale Konten und längere Passwörter oder zusätzliche Authentifizierung für Konten mit besonderen Rechten, mindestens zwanzig Zeichen für WLAN und verschlüsselte Dateien, einen Wechsel bei jedem Verdacht, dass ein Passwort anderen bekannt wurde, und Passwort-Manager; Sicherheitsschlüssel beschreibt es als wirksame Maßnahme gegen Phishing und Man-in-the-Middle-Angriffe. Eine noch online stehende WKO-Seite von 2016 empfiehlt acht Zeichen und einen Wechsel alle drei bis sechs Monate; die eigene WKO-Meldung vom Jänner 2026 sagt das Gegenteil: Länge zählt, mindestens zwölf Zeichen, Wechsel nur bei konkretem Verdacht.

→ onlinesicherheit.gv.at (Bundeskanzleramt und A-SIT), „Passwort-Auswahl“ (Stand 9. Dezember 2025), „Passwort-Umgang“ (6. Februar 2020), Beitrag zu FIDO-Sicherheitsschlüsseln (19. September 2023) · Abruf 2026-10-19; WKO, „Passwörter: Die Schlüssel zu Computer und Internet“, Stand 6. Juni 2016, und WKO Kärnten, „Passwort vergessen, Konto gesperrt“, aktualisiert 28. Jänner 2026 · wko.at · Abruf 2026-10-19

**FAKT** Für Betriebe, die unter NIS 2 fallen, müssen die Maßnahmen grundlegende Cyberhygiene und Schulungen, Konzepte für die Zugriffskontrolle und die Verwendung von Multi-Faktor- oder kontinuierlicher Authentifizierung umfassen, soweit angemessen. Deutschland und Österreich haben diesen Wortlaut in ihre Gesetze übernommen.

→ Richtlinie (EU) 2022/2555, Art. 21 Abs. 2 Buchst. g, i und j · EUR-Lex · Abruf 2026-10-19; BSI-Gesetz, § 30 Abs. 2 Nr. 10 · gesetze-im-internet.de · Abruf 2026-10-19; NISG 2026, § 32 Abs. 4 lit. j · ris.bka.gv.at · Abruf 2026-10-19

**AUSLEGUNG** Multi-Faktor-Authentifizierung ohne geprobte Wiederherstellung sperrt den Betrieb aus, wenn ein Telefon verloren geht oder die Administratorin ausfällt. Ausgedruckte, offline aufbewahrte Wiederherstellungscodes, eine zweite Administratorin und ein datierter Test des Verfahrens gehören zum selben Schritt.

**LÜCKE** Keine gelesene Quelle nennt ein gesetzliches Mindestmaß für die Anmeldesicherheit eines Betriebs außerhalb von NIS 2. Die Maßstäbe oben sind das, was die Behörden empfehlen und wonach Sicherheitsfragebögen fragen; ein Vertrag mit einem Kunden oder Versicherer kann mehr verlangen.

**UNSICHER** Die Verbraucherseiten des BSI tragen kein Datum; der gelesene IT-Grundschutz-Baustein stammt aus der Edition 2023, der letzten Vollausgabe; das BSI führt IT-Grundschutz++ ein (Stand prüfen auf bsi.bund.de). CISA nennt die Forschung hinter seiner 99-%-Zahl nicht; die Zahl wird als dessen Aussage wiedergegeben, nicht als Messung dieses Memos.

## Was als Nächstes zu tun ist

- [ ] Diese Woche: Multi-Faktor-Authentifizierung für jedes E-Mail-Konto und jedes Administrator-, Fernzugriffs-, Banking-, Shop- und Cloud-Konto einschalten; Authenticator-App oder Sicherheitsschlüssel, SMS nur als letzte Möglichkeit.
- [ ] Führen Sie einen Passwort-Manager für alle ein; ein langes Passwort je Konto, 15 Zeichen oder mehr ohne zweiten Faktor; sonst mindestens 12 (onlinesicherheit.gv.at; NIST setzt mit MFA 8 als Untergrenze); kein erzwungener Wechsel; Änderung bei Verdacht; keine geteilten Logins.
- [ ] Schreiben Sie eine Liste aller Konten und wer sie hat; eine Austrittscheckliste, die Konten am selben Tag deaktiviert; ausgedruckte, offline aufbewahrte Wiederherstellungscodes; eine zweite Administratorin; ein datierter Test der Wiederherstellung.
- [ ] Schreiben Sie die drei Schritte als einseitige Anmelderegel auf und halten Sie datiert fest, was wann eingeschaltet wurde; das ist der Nachweis, nach dem ein Fragebogen fragt.

Das Sicherheitsnachweis-Toolkit macht aus diesen Schritten und den weiteren Maßnahmen, nach denen Kunden oder Versicherer fragen, eine Selbstauskunft, einen Maßnahmenplan und eine Notfallkarte: scutoria.com/de/toolkits/sicherheitsnachweis.

## Quellen


1. NIST Special Publication 800-63B-4, Digital Identity Guidelines: Authentication and Authenticator Management, Juli 2025, veröffentlicht am 1. August 2025, ersetzt Revision 3: Abschnitte 3.1.1.1, 3.1.1.2, 3.2.2, 4.2. pages.nist.gov/800-63-4/sp800-63b.html und doi.org/10.6028/NIST.SP.800-63B-4 · Abruf 2026-10-19.
2. BSI, Pressemitteilung vom 31. Januar 2025, „Passwortwechseln war gestern“, und vom 30. Januar 2026, „Der Ändere-dein-Passwort-Tag braucht ein Update“; Verbraucherseiten „Sichere Passwörter erstellen“, „Umgang mit Passwörtern“ und „Zwei-Faktor-Authentisierung“ (undatiert). bsi.bund.de · Abruf 2026-10-19.
3. BSI, IT-Grundschutz-Kompendium, Edition 2023: ORP.4 Identitäts- und Berechtigungsmanagement (A1, A2, A8, A9, A22, A23); ORP.2 Personal (A2). bsi.bund.de · Abruf 2026-10-19. Die Edition 2023 ist die letzte Vollausgabe; das BSI führt IT-Grundschutz++ ein (Stand prüfen auf bsi.bund.de; heise, „IT-Grundschutz++“, und SVA, Flyer 2026 · Abruf 2026-10-23).
4. CISA, Fact Sheet „Implementing Phishing-Resistant MFA“, Oktober 2022; Pressemitteilung vom 6. Juni 2022 zur Kampagne „More Than a Password“; Blog „Walk this way to enable MFA“, 5. Mai 2022. cisa.gov · Abruf 2026-10-19.
5. Microsoft, Digital Defense Report 2023 (Berichtszeitraum Juli 2022 bis Juni 2023); Microsoft Research, „How effective is multifactor authentication at deterring cyberattacks?“, Mai 2023; Microsoft Security Blog, 20. August 2019. microsoft.com · Abruf 2026-10-19.
6. ENISA, „Cybersecurity guide for SMEs: 12 steps to securing your business“, Juni 2021, und „Cybersecurity for SMEs: Challenges and Recommendations“, Juni 2021. enisa.europa.eu · Abruf 2026-10-19.
7. Österreich: onlinesicherheit.gv.at, „Passwort-Auswahl“ (9. Dezember 2025), „Passwort-Umgang“ (6. Februar 2020), „Mehrfaktor-Authentifizierung“ (6. Oktober 2020), Beitrag zu FIDO-Sicherheitsschlüsseln (19. September 2023); WKO, „Mehr Sicherheit durch Mehr-Faktor-Authentifizierung“ (12. September 2022), „Passwörter: Die Schlüssel zu Computer und Internet“ (6. Juni 2016), WKO Kärnten, Beitrag vom 28. Jänner 2026. Abruf 2026-10-19.
8. Richtlinie (EU) 2022/2555 (NIS 2), Art. 21 Abs. 2. eur-lex.europa.eu · Abruf 2026-10-19. Deutschland: BSI-Gesetz vom 2. Dezember 2025, § 30 Abs. 2. gesetze-im-internet.de · Abruf 2026-10-19. Österreich: NISG 2026, BGBl. I Nr. 94/2025, § 32 Abs. 4, in Kraft seit 1. Oktober 2026. ris.bka.gv.at · Abruf 2026-10-19.

Dieses Memo ist eine Information auf Grundlage der genannten Quellen, erzeugt am 23. Oktober 2026 aus den Antworten oben. Es ist keine Rechtsberatung und entscheidet nichts anstelle Ihres Betriebs. Jede Aussage trägt ihren Marker, jede Quelle ihr Abrufdatum; prüfen Sie die Quellen erneut, bevor Sie sich auf eine Frist verlassen.